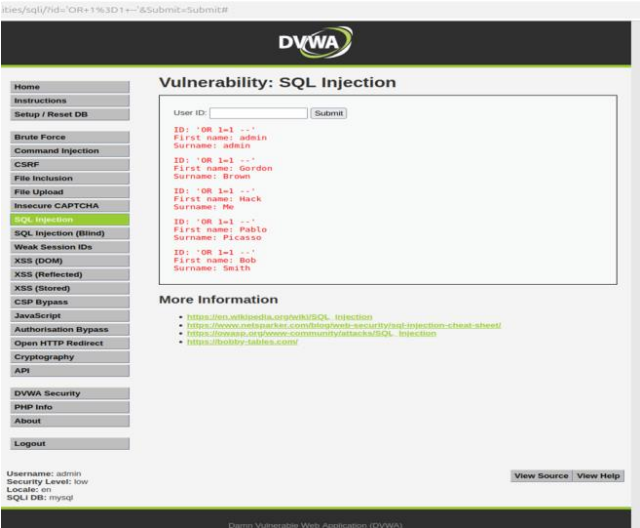


SQL Injection Practice:

Use Damn Vulnerable Web App (DVWA) to test SQL Injection attacks on a test environment.



Try using sqlmap to automate SQL Injection detection.

```
kali@kali:~/Downloads$ sqlmap -u "http://localhost/DVWA/vulnerabilities/sql/?" --cookie="OR=1&3D1=1--&Submit=Submit#" --risk=3 --level=5
[1.0.40stable]
https://sqlmap.org

[!] Legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 21:04:23 /2025-01-30/

[21:04:23] [WARNING] you've provided target URL without any GET parameters (e.g. 'http://www.site.com/article.php?id=1') and without providing any POST parameters through option '--data'
do you want to try URI injections in the target URL itself? [Y/n/q] y
[21:04:25] [INFO] testing connection to the target URL
got a 302 redirect to "http://localhost/DVWA/login.php". Do you want to follow? [Y/n] y
[21:04:26] [INFO] checking if the target is protected by some kind of WAF/IPS
[21:04:26] [INFO] testing if the target URL content is stable
[21:04:26] [WARNING] URI parameter 'id' does not appear to be dynamic
[21:04:26] [WARNING] heuristic (basic) test shows that URI parameter 'id' might not be injectable
[21:04:26] [INFO] testing for SQL injection on URI parameter 'id'
[21:04:26] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause'
[21:04:26] [INFO] testing 'OR boolean-based blind - WHERE or HAVING clause'
[21:04:26] [INFO] testing 'OR boolean-based blind - WHERE or HAVING clause (NOT - comment)'
[21:04:26] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause (subquery - comment)'
[21:04:26] [INFO] testing 'OR boolean-based blind - WHERE or HAVING clause (subquery - comment)'
[21:04:26] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause (comment)'
[21:04:26] [INFO] testing 'OR boolean-based blind - WHERE or HAVING clause (comment)'
[21:04:26] [INFO] testing 'OR boolean-based blind - WHERE or HAVING clause (NOT - comment)'
[21:04:26] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause (MySQL comment)'
[21:04:26] [INFO] testing 'OR boolean-based blind - WHERE or HAVING clause (MySQL comment)'
[21:04:26] [INFO] testing 'OR boolean-based blind - WHERE or HAVING clause (MySQL comment)'
[21:04:26] [INFO] testing 'OR boolean-based blind - WHERE or HAVING clause (MySQL comment)'
[21:04:26] [INFO] testing 'OR boolean-based blind - WHERE or HAVING clause (MySQL comment)'
[21:04:26] [INFO] testing 'MySQL RLIKE boolean-based blind - WHERE, HAVING, ORDER BY or GROUP BY clause (MAKE_SET)'
[21:04:26] [INFO] testing 'MySQL AND boolean-based blind - WHERE, HAVING, ORDER BY or GROUP BY clause (MAKE_SET)'
[21:04:26] [INFO] testing 'MySQL OR boolean-based blind - WHERE, HAVING, ORDER BY or GROUP BY clause (MAKE_SET)'
[21:04:26] [INFO] testing 'MySQL OR boolean-based blind - WHERE, HAVING, ORDER BY or GROUP BY clause (ELT)'
[21:04:26] [INFO] testing 'MySQL AND boolean-based blind - WHERE, HAVING, ORDER BY or GROUP BY clause (ELT)'
[21:04:26] [INFO] testing 'MySQL AND boolean-based blind - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)'
[21:04:26] [INFO] testing 'MySQL OR boolean-based blind - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)'
[21:04:26] [INFO] testing 'PostgreSQL AND boolean-based blind - WHERE or HAVING clause (CAST)'
[21:04:26] [INFO] testing 'PostgreSQL OR boolean-based blind - WHERE or HAVING clause (CAST)'
```

```
[21:15:19] [INFO] testing 'MySQL >= 5.0.12 time-based blind - Parameter replace (heavy query)' - PROCEDURE ANALYSE (EXTRACT(VALUE))
[21:15:19] [INFO] testing 'MySQL >= 5.0.12 time-based blind - Parameter replace (subtraction)'
[21:15:19] [INFO] testing 'MySQL < 5.0.12 time-based blind - Parameter replace (BENCHMARK)'
[21:15:19] [INFO] testing 'MySQL > 5.0.12 time-based blind - Parameter replace (heavy query - comment)'
[21:15:19] [INFO] testing 'MySQL time-based blind - Parameter replace (bool)'
[21:15:19] [INFO] testing 'MySQL time-based blind - Parameter replace (ELT)'
[21:15:19] [INFO] testing 'MySQL time-based blind - Parameter replace (MAKE_SET)'
[21:15:19] [INFO] testing 'PostgreSQL >= 8.1 time-based blind - Parameter replace'
[21:15:19] [INFO] testing 'PostgreSQL time-based blind - Parameter replace (heavy query)'
[21:15:19] [INFO] testing 'Microsoft SQL Server/Sybase time-based blind - Parameter replace (heavy queries)'
[21:15:19] [INFO] testing 'Oracle time-based blind - Parameter replace (DBMS_LOCK.SLEEP)'
[21:15:19] [INFO] testing 'Oracle time-based blind - Parameter replace (DBMS_PIPE.RECEIVE_MESSAGE)'
[21:15:19] [INFO] testing 'Oracle time-based blind - Parameter replace (heavy queries)'
[21:15:19] [INFO] testing 'SQLite > 2.0 time-based blind - Parameter replace (heavy query)'
[21:15:19] [INFO] testing 'Firebird time-based blind - Parameter replace (heavy query)'
[21:15:19] [INFO] testing 'SAP MaxDB time-based blind - Parameter replace (heavy query)'
[21:15:19] [INFO] testing 'IBM DB2 time-based blind - Parameter replace (heavy query)'
[21:15:19] [INFO] testing 'HSQLDB >= 1.7.2 time-based blind - Parameter replace (heavy query)'
[21:15:19] [INFO] testing 'HSQLDB > 2.0 time-based blind - Parameter replace (heavy query)'
[21:15:19] [INFO] testing 'Informix time-based blind - Parameter replace (heavy query)'
[21:15:19] [INFO] testing 'MySQL >= 5.0.12 time-based blind - ORDER BY, GROUP BY clause'
[21:15:19] [INFO] testing 'MySQL < 5.0.12 time-based blind - ORDER BY, GROUP BY clause (BENCHMARK)'
[21:15:19] [INFO] testing 'PostgreSQL > 8.1 time-based blind - ORDER BY, GROUP BY clause'
[21:15:19] [INFO] testing 'PostgreSQL time-based blind - ORDER BY, GROUP BY clause (heavy query)'
[21:15:19] [INFO] testing 'Microsoft SQL Server/Sybase time-based blind - ORDER BY clause (heavy query)'
[21:15:19] [INFO] testing 'Oracle time-based blind - ORDER BY, GROUP BY clause (DBMS_LOCK.SLEEP)'
[21:15:19] [INFO] testing 'Oracle time-based blind - ORDER BY, GROUP BY clause (DBMS_PIPE.RECEIVE_MESSAGE)'
[21:15:19] [INFO] testing 'Oracle time-based blind - ORDER BY, GROUP BY clause (heavy query)'
[21:15:19] [INFO] testing 'HSQLDB > 1.7.2 time-based blind - ORDER BY, GROUP BY clause (heavy query)'
[21:15:20] [INFO] testing 'HSQLDB > 2.0 time-based blind - ORDER BY, GROUP BY clause (heavy query)'
[21:15:20] [INFO] testing 'Generic UNION query (NULL) - 1 to 10 columns'
[21:15:21] [INFO] testing 'Generic UNION query (random number) - 1 to 10 columns'
[21:15:22] [INFO] testing 'MySQL UNION query (NULL) - 1 to 10 columns'
[21:15:23] [INFO] testing 'MySQL UNION query (random number) - 1 to 10 columns'
[21:15:24] [WARNING] parameter 'Host' does not seem to be injectable
[21:15:24] [CRITICAL] all tested parameters do not appear to be injectable. If you suspect that there is some kind of protection mechanism involved (e.g. WAF) maybe you could try to use option --tamper (e.g. --tamper=space2comment) and/or switch --random-agent!
[21:15:24] [WARNING] HTTP error codes detected during run:
404 (Not Found) - 8668 times, 403 (Forbidden) - 191 times
[21:15:24] [WARNING] your sqlmap version is outdated

[*] ending @ 21:15:24 /2025-01-30/

msf6@kali:~/IdeaPad-3-15TAMT-5
```

Use Burp Suite for Web Traffic

Analysis:

Burp Suite Community Edition v2024.12.1 - Temporary Project

Dashboard

Intercept

HTTP history

WebSockets history

Match and replace

Proxy settings

Filter settings: Hiding CSS, image and general binary content

#	Host	Method	URL	Params	Et	Status	Length	MIME type	Ext	Tid	NTLS	IP	Cookies
334	https://www.youtube.com	GET	/sw.js_data		200	3312	JSON					142.250.77.206	
336	https://www.youtube.com	POST	/youtubei/v1/notification_registration...		200	3242	JSON					142.250.77.206	
339	https://www.youtube.com	POST	/youtubei/v1/feedback?prettyPrint=...		200	3415	JSON					142.250.77.206	
352	https://www.youtube.com	GET	/sw.js		200	10182	script	js				142.250.77.206	
357	https://www.youtube.com	POST	/youtubei/v1/tiger?prettyPrint=false		200	37227	JSON					142.250.77.206	
359	https://www.youtube.com	POST	/youtubei/v1/log_event?alt=json		200	370	JSON					142.250.77.206	
363	https://www.youtube.com	POST	/youtubei/v1/guide?prettyPrint=false		200	17578	JSON					142.250.77.206	
364	https://www.youtube.com	GET	/generate_2047TGAMQg		204	182						142.250.77.206	
368	https://www.youtube.com	POST	/youtubei/v1/feedback?prettyPrint=...		200	3406	JSON					142.250.77.206	
371	https://www.youtube.com	POST	/api/push/GenerateId		200	422	JSON					142.250.77.206	
372	https://www.youtube.com	GET	/sw.js		200	10182	script	js				142.250.77.206	
375	https://www.youtube.com	POST	/youtubei/v1/log_event?alt=json		200	370	JSON					142.250.77.206	
536	https://www.youtube.com	POST	/youtubei/v1/log_event?alt=json		200	370	JSON					142.250.77.206	
551	https://www.youtube.com	POST	/youtubei/v1/log_event?alt=json		200	370	JSON					142.250.193.238	
586	https://www.youtube.com	GET	/		200	10182	script	js				142.250.193.238	
607	https://www.youtube.com	POST	/youtubei/v1/log_event?alt=json		200	370	JSON					142.250.193.238	
610	https://www.youtube.com	GET	/		200	10182	script	js				142.250.193.238	
611	https://www.youtube.com	GET	/sw.js		200	10182	script	js				142.250.193.238	
614	https://www.youtube.com	POST	/youtubei/v1/log_event?alt=json		200	370	JSON					142.250.194.14	
619	https://www.youtube.com	POST	/youtubei/v1/log_event?alt=json		200	370	JSON					142.250.192.206	
622	https://www.youtube.com	POST	/youtubei/v1/log_event?alt=json		200	370	JSON					142.250.193.14	
633	https://www.youtube.com	POST	/youtubei/v1/log_event?alt=json		200	370	JSON					172.217.166.14	
646	https://www.youtube.com	POST	/youtubei/v1/log_event?alt=json		200	370	JSON					216.58.200.174	
121	https://www.youtube.com	GET	/app_shell		200	521587	HTML					142.250.77.206	GPS=L: VISITOR_INFO_LIVE=eq7OX30dSYM: VISITOR_PRIV
121	https://www.youtube.com	GET	/		200	583762	HTML					142.250.193.206	GPS=L: YSC=Jj12h2Y: __Secure-ROLLOUT_TOKEN=CPW

Request

1 POST /youtubei/v1/log_event?alt=json HTTP/2

2 Host: www.youtube.com

3 Cookie: __Secure-ROLLOUT_TOKEN=CPW6W1C701y3yAEQ8p9uucC1wM7upqLHQ4LwM3D; VISITOR_INFO_LIVE=eq7OX30dSYM; VISITOR_PRIV_VACY_METADATA=Ag3Jth1EG0gAghyN30N3D; PREF=tz=Asia.Kolkata; __Secure-SPSIDT5=...CJEBuPVTXVH2G5U7VJ3QX0P7G3M4H21_PMHQXQ1U514QW4U4uKuc29H4CQ_8LEAA; LOGIN_INFO=AFmZuWRAI3G4SRLUwFwTvgB72BAAmKmu1vLd_MW9GctF12cCtBLQdJ0RvSKT8T7vzp_g2QW4VMSRBAQW6y00; QU3M9NmLZJTDBGQK56Uk1NQJ3C366VETZLIUYPfDck9cmvPBxLEtkTxMBuX3FCnpMeVdKXpQD4W1ATL4L3Lp4b4h4c1PM5YTV2VYv4AD1K2D1S12QV4QV0H0R0d4S14N4ZLWY0E2W4V4AT4ZP0B4V4N4ZP4H4Z5V4F4V0H4H4R; YSC=Jj12h2Y

4 User-Agent: Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:134.0) Gecko/20100101 Firefox/134.0

5 Accept: */*

6 Accept-Language: en-US,en;q=0.5

7 Accept-Encoding: gzip, deflate, br

8 Content-Type: application/json

9 Content-Length: 1326

10 Referer: https://www.youtube.com/

11 X-Goog-Request-Time: 173825068513

12 X-Goog-Data-From-Traffic: 101v1N1M2w27h27T5C1Ku498N1K6Cn13TATFC0d4b6bK9K9Q

Inspector

Request attributes

2

Request query parameters

1

Request cookies

8

Request headers

36

Event log (17)

All issues

Memory: 237.8MB

Request
 Pretty Raw Hex

```

1 POST /v1/rgrstr?k=client-tNE5G0U2F2cTxRbMbv7czMDT1jpw1g2hs25dqi4u&st=javascript-client-react&sv=3.9.0&t=1738248350495&sid=79ea78ba-9abd-4940-b8ef-ab7116f5aaf1&ec=2 HTTP/2
2 Host: ab.chatgpt.com
3 User-Agent: Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:134.0) Gecko/20100101 Firefox/134.0
4 Accept: */*
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Referer: https://chatgpt.com/
8 Content-Type: text/plain; charset=UTF-8
9 Content-Length: 1243
10 Origin: https://chatgpt.com
11 Sec-Fetch-Dest: empty
12 Sec-Fetch-Mode: cors
13 Sec-Fetch-Site: same-site
14 Priority: u=4
15 Te: trailers
16
17 {
  "events": [
    {

```

Inspector
 Request attributes
 Protocol: HTTP/1.1, HTTP/2
 Name: Value
 Method: POST
 Path: /v1/rgrstr
 Request query parameters: 6
 Request cookies: 0
 It's empty in here
 Add
 Request headers: 17

Event log (17) All issues
 Memory: 260.0MB

Mini Web Scraping Task:

Write a Python script using BeautifulSoup or Scrapy to scrape public data (like news headlines) from a website.

Bonus: Implement user-agent rotation to avoid detection.

```

aditi@aditi-IdeaPad-3-15IAU7:~$ nano scrape.py
aditi@aditi-IdeaPad-3-15IAU7:~$ cat scrape.py
import requests
from bs4 import BeautifulSoup
import random

# User-Agent rotation
user_agents = [
    "Mozilla/5.0 (Windows NT 10.0; Win64; x64)",
    "Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7)",
    "Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:89.0)"
]

headers = {"User-Agent": random.choice(user_agents)}
url = "https://news.ycombinator.com/"

# Fetch data
response = requests.get(url, headers=headers)
soup = BeautifulSoup(response.text, "html.parser")

# Extract headlines
for item in soup.select(".title a"):
    print(item.text)
aditi@aditi-IdeaPad-3-15IAU7:~$ █

```

```

aditi@aditi-IdeaPad-3-15IAU7:~$ nano scrape.py
aditi@aditi-IdeaPad-3-15IAU7:~$ python3 scrape.py
JavaScript Temporal is coming
developer.mozilla.org
Note on the Relationship Between Artificial Intelligence and Human Intelligence
vatican.va
Mistral Small 3
mistral.ai
My home built pipe organ
sentex.ca
Rust's worst feature
m1na86.com
PCBs, copper pours, ground planes, and you
lcamtuf.substack.com
Investigating the case of human nose shape and climate adaptation (2017)
plos.org
Piled High: 17th-Century Dutch Banquet Scenes
publicdomainreview.org
Permission to Practise Medicine
blogs.bl.uk
Analysis of 76,882 Product Hunt Products, from 2014 - 2021
components.one
An analysis of DeepSeek's R1-Zero and R1
arcprize.org
Building a T1D smartwatch for my son from scratch
andrewchilds.com
Codes Health (YC S24) Is Hiring
SmolGPT: A minimal PyTorch implementation for training a small LLM from scratch
github.com/om-alve
Goethe's "Sorcerer's Apprentice" - power over wisdom
wilderutopia.com
Teemoji: Like Tee but with Emojis
github.com/willswire
Mathesar - an intuitive spreadsheet-like interface to Postgres data
github.com/mathesar-foundation
Commercial jet collides with Black Hawk helicopter near Reagan airport
mediaite.com
Decompiling 2024: A Year of Resurgence in Decompilation Research
mahaloz.re
Detecting edges of images at the speed of light

```